

THE GOVERNANCE · TG-FW-02

Shadow AI Risk Assessment

Kurumda Görünmez AI Kullanımını Haritalayın ve Skore Edin

Kontrol dışı AI araç kullanımı · KVKK & veri sızıntısı riski · Hızlı tarama aracı

thegovernance.com.tr

© 2026 The Governance · Tüm hakları saklıdır.

01 Shadow AI Nedir?

Shadow AI; kurumun resmi onay ve politika çerçevesi dışında, çalışanlar tarafından kullanılan yapay zeka araçlarını ifade eder. ChatGPT, Claude, Gemini, Midjourney ve benzeri araçların kurumsal süreçlere dahil edilmesi — BT ve risk yönetiminin haberi olmadan — shadow AI riskini oluşturur.

NEDEN ACİL?

Gizli kurumsal veriler harici AI modellerine gönderilebilir. KVKK Madde 12 kapsamında veri sızıntısı riski oluşur. Hukuki sorumluluk kuruma aittir.

02 Hızlı Tarama — 10 Tanı Sorusu

Aşağıdaki soruları çalışan anketi veya iç görüşme yoluyla uygulayın. Her "Evet" yanıtı 1 puan. 7+ puan: Acil müdahale gerekli.

1	Çalışanlar iş e-postası veya kurumsal hesap olmadan AI araç kullanıyor mu?	☐ Evet ☐ Hayır
2	Kurumsal belgeler, sözleşmeler veya müşteri verileri AI araçlara yapıştırılıyor mu?	☐ Evet ☐ Hayır
3	BT departmanı hangi AI araçların kullanıldığını haberdar değil mi?	☐ Evet ☐ Hayır
4	AI araç kullanımı için yazılı bir politika veya onay süreci mevcut değil mi?	☐ Evet ☐ Hayır
5	Çalışanlar AI çıktısını doğrulamadan doğrudan kullanıyor mu?	☐ Evet ☐ Hayır
6	Tedarikçiler veya üçüncü taraflar AI kullanıyor mu, bu bilinmiyor mu?	☐ Evet ☐ Hayır
7	KVKK kapsamında kişisel veri içeren içerikler AI araçlara giriliyor mu?	☐ Evet ☐ Hayır
8	Hangi AI araçların ne sıklıkla kullanıldığını dair kayıt tutulmuyor mu?	☐ Evet ☐ Hayır
9	Çalışanlara AI araç güvenliği konusunda eğitim verilmedi mi?	☐ Evet ☐ Hayır
10	AI çıktısı hukuki belgeler, finansal raporlar veya müşteri tekliflerinde kullanılıyor mu?	☐ Evet ☐ Hayır

03 Risk Skoru Yorumlama Rehberi

0-3	DÜŞÜK	Temel politika oluşturma ve farkındalık eğitimi yeterli.
4-6	ORTA	Politika acilen oluşturulmalı. AI araç envanteri çıkarılmalı.
7-9	YÜKSEK	Acil müdahale gerekli. Veri sınıflandırması ve erişim kontrolü.
10	KRİTİK	Olası KVKK ihlali. Hukuk ve uyum ekibi devreye girmeli.

04 Sonraki Adımlar — 30-60-90 Gün Planı

30 GÜN

AI araç envanteri çıkarın. Hangi ekipler, hangi araçları kullanıyor? KVKK kapsamında kişisel veri işlenen araçları işaretleyin.

60 GÜN

AI kullanım politikası taslağı hazırlayın. Onaylı araç listesi belirleyin. Çalışan farkındalık eğitimi planlayın.

90 GÜN

Politikayı yürürlüğe alın. Tedarikçi AI kullanımını sözleşmeye yansıtın. İlk denetim döngüsünü başlatın. YK'ya raporlayın.

"Shadow AI, kurumun göremediği risktir. Göremediğinizi yönetemezsiniz."

— The Governance, 2026

Bu framework The Governance tarafından ücretsiz sunulmaktadır. Kuruma özel Shadow AI taraması ve politika geliştirme için: ecem@thegovernance.com.tr · thegovernance.com.tr